

公司信息安全与数据管理制度

> 版本：v 2 . 1 生效日期：2 0 2 6 - 0 1 - 0 1 修订：信息安全管理委员会

第一章 总则

1 . 1 目的与适用范围

为保障公司信息系统、业务数据与客户隐私的安全，规范全体员工的信息安全行为，防范数据泄露、网络攻击与内部违规，特制定本制度。本制度适用于公司在职员工、实习生、外包人员以及所有接入公司信息系统的第三方人员。所有人员在入职时应签署《保密协

1 . 2 信息安全三要素

公司信息安全遵循机密性（C o n f i d e n t i a l i t y）、完整性（I n t e g r i t y）、可用性（A v a i l a b

- * * 机密性 * *：确保数据仅被授权人员访问，防止未授权泄露。
- * * 完整性 * *：确保数据在传输与存储过程中不被篡改。
- * * 可用性 * *：确保系统在业务需要时能够正常访问与使用。

1 . 3 组织架构

公司设立信息安全管理委员会作为最高决策机构，下设信息安全办公室（负责日常执行）与各业务部门信息安全联络员（负责

- - -

第二章 账号与访问控制

2 . 1 账号管理

- 所有员工入职当天由 I T 部门统一开通账号，实行 " 一人一号、实名制 "。
- 离职员工账号应在离职当天（不得晚于 1 2 : 0 0）由系统自动停用。
- 员工不得将账号借用、共享给他人，一经发现按严重违规处理。

2 . 2 密码策略

- 密码长度 * * 不少于 1 2 位 * *，须同时包含大写字母、小写字母、数字和特殊字符。
- 密码 * * 每 9 0 天强制更换一次 * *，且不得与最近 5 次历史密码重复。
- 连续 5 次输入错误密码，账号将被锁定 3 0 分钟。
- 禁止使用生日、手机号、连续数字等弱密码。

2 . 3 多因素认证

访问公司核心系统（财务系统、代码仓库、生产环境）必须启用 * * 多因素认证（M F A）* *。公司推荐使用企业微信扫码

2 . 4 权限最小化原则

- 员工仅能访问完成本职工作所需的最小权限，遵循 " 按需授权、默认拒绝 "。
- 权限申请需经直属主管审批，并在系统中留痕。
- 每半年进行一次权限复核，清理长期未使用的账号与过高权限。

- - -

第三章 数据安全

3 . 1 数据分级

公司数据依据敏感程度分为四级：

级别	定义	示例	保护要求
: - - -	: - - -	: - - -	: - - -
L 1	公开数据	公司简介、官网信息	无特殊要求
L 2	内部数据	内部制度、组织架构	仅限内部访问
L 3	机密数据	客户名单、合同、财务数据	加密存储、按需授权
L 4	绝密数据	核心算法、源代码、用户隐私	加密 + 脱敏 + 审计

3 . 2 数据加密

- 存储加密：L 3 及以上数据在数据库与文件存储中必须加密（A E S - 2 5 6）。
- 传输加密：所有内外部数据传输必须使用 T L S 加密（H T T P S）。
- 备份加密：备份文件落盘前必须加密，备份密钥与备份数据分开存放。

3 . 3 数据备份与恢复

- 核心数据每日自动备份，保留周期不少于 9 0 天。
- 每月进行一次 * * 恢复演练 * *，确保备份可恢复、恢复时间目标（R T O）不超过 4 小时。
- 备份数据存储于异地机房，与主数据隔离。

3 . 4 数据脱敏

- 在开发、测试、演示环境中使用真实数据前，必须进行 * * 脱敏处理 * *（如手机号、身份证、邮箱等替换为伪造值）。
- 生产数据导出至测试环境需经信息安全办公室审批。

3 . 5 数据销毁

- 达到保留期限的数据应按安全标准销毁，物理介质（硬盘、U 盘）须进行消磁或物理粉碎。
- 云端数据删除后 3 0 天内应在所有副本中彻底清除。

- - -

第四章 网络安全

4 . 1 网络划分

- 公司网络划分为 * * 办公区、生产区、DMZ 区（隔离区） * * 三个安全域，通过防火墙
- 生产区与办公区之间禁止直接互通，须经由跳板机（堡垒机）访问。

4.2 防火墙与入侵检测

- 互联网边界部署防火墙，默认 * * 拒绝所有入站流量 * *，仅放行白名单端口。
- 部署入侵检测系统（IDS）与入侵防御系统（IPS），对异常流量实时告警。
- 每季度进行一次漏洞扫描，高危漏洞须在 7 天内修复。

4.3 无线网络安全

- 办公 Wi-Fi 使用 WPA3 加密，并区分访客网络与员工网络。
- 访客网络与员工网络物理隔离，访客网络仅能访问互联网。

4.4 远程访问

- 远程办公必须通过公司的 VPN 接入，使用多因素认证。
- VPN 账号仅限本人使用，禁止在公共 Wi-Fi 上未加密连接公司资源。

- - -

第五章 终端与设备安全

5.1 终端设备

- 公司配发的笔记本电脑出厂即启用全盘加密（BitLocker / FileVault）。
- 员工不得在办公终端安装来源不明的软件，如确需安装需经 IT 审批。
- 操作系统与软件须及时更新安全补丁，避免使用存在已知漏洞的版本。

5.2 移动设备

- 员工使用个人手机处理工作邮件时，须开启设备锁屏与远程擦除功能。
- 严禁在未加密的个人设备上存储 L3 及以上级别数据。

5.3 办公环境

- 办公区域门禁刷卡进入，重要区域（机房、财务室）实行双人进入制度。
- 离开工位须锁屏，防止桌面上的敏感信息被无关人员查看。

- - -

第六章 邮件与安全

6.1 邮件安全

- 不打开来源不明的邮件附件，不点击可疑链接，谨防钓鱼攻击。

- 涉及转账、改账号等敏感操作的邮件，须通过电话或当面二次确认。
- 公司邮件系统已部署反钓鱼与邮件网关过滤器，可疑邮件会自动标记。

6 . 2 安全事件报告

- 发现疑似钓鱼、病毒、数据泄露等安全事件，须在 * * 2 小时内 * * 上报信息安全办公室。
- 员工不得擅自删除、销毁安全事件相关证据。
- 公司对及时报告安全事件且未造成损失的员工给予奖励。
- - -

第七章 供应商与第三方管理

7 . 1 供应商准入

- 供应商接入公司系统前，须完成安全评估，签署信息安全附件。
- 优先选择通过 I S O 2 7 0 0 1 认证的供应商。

7 . 2 外包与临时人员

- 外包人员访问公司系统须使用独立账号，权限按项目最小化授权。
- 项目结束后，外包人员账号在 2 4 小时内停用。
- - -

第八章 违规处理

8 . 1 违规分级

级别	定义	处理措施
: - - -	: - - -	: - - -
轻微违规	未锁屏、密码设置不合规等	口头警告、限期整改
一般违规	共享账号、未打补丁等	书面警告、扣除绩效
严重违规	泄露 L 3 数据、私自外传等	通报批评、追究责任
特别严重	泄露 L 4 数据、内鬼窃密等	解除劳动合同、移交司法

8 . 2 上报渠道

- 员工可通过信息安全办公室邮箱、内网举报平台或匿名渠道上报违规行为。
- 公司对举报人信息严格保密，严禁打击报复。
- - -

第九章 附则

9 . 1 制度修订

本制度由信息安全管理委员会负责解释与修订，原则上每两年复审一次，重大安全事件或法规变

9 . 2 生效

本制度自发行之日起施行，原有相关制度同时废止。全体员工应自觉遵守，共同维护公司信息安全。

- - -

附录：信息安全自查清单（每月）

- [] 是否完成了本月的强制密码更换？
- [] 离开工位是否锁屏？
- [] 是否在未授权设备上存储了敏感数据？
- [] 是否及时更新了操作系统与软件补丁？
- [] 是否收到过可疑邮件并已上报？
- [] 近期账号权限是否与当前岗位职责一致？

- - -

* 以上内容纯属虚构，用于演示 R A G 知识库问答系统的检索能力。 *